

Definición de roles

- **ROLE_ADMIN:** gestiona médicos, especialidades, configura normativas.
- **ROLE_DOCTOR:** atiende citas, escribe recetas, accede a historial.
- **ROLE_PACIENTE:** reserva, cancela, accede a recetas.

Descripción de roles

Administrador (ROLE_ADMIN)

Rol encargado de controlar, configurar y supervisar que la plataforma funcione bajo las reglas de negocio.

- **Permisos de escritura:** * Creación, actualización y eliminación de perfiles de doctores.
 - Creación, actualización y eliminación de especialidades.
 - Configurar las normativas del sistema.
 - Anonimización de datos personales del paciente (cumplimiento de la ley GDPR).
- **Permisos de lectura:** * Acceder al reporte de doctores más solicitados.
 - Acceso a los logs de auditoría del sistema.

Matriz de permisos: Rol Administrador

Módulo	Endpoint de la API	Método HTTP	Acción de Negocio	Justificación / Regla
Médicos	/api/v1/doctores	POST	Registrar médico	Permite dar de alta a nuevos especialistas en el sistema.
Médicos	/api/v1/doctores/{id}	PUT	Modificar médico	Permite actualizar la información contractual o estado del médico.

Médicos	/api/v1/doctores/{id}	DELETE	Dar de baja médico	Eliminación lógica de un médico en el catálogo del sistema.
Especialidades	/api/v1/especialidades	POST	Crear especialidad	Define una nueva rama médica en el catálogo general.
Especialidades	/api/v1/especialidades/{id}	PUT	Modificar especialidad	Permite editar el nombre o descripción de la especialidad.
Especialidades	/api/v1/especialidades/{id}/estado	PATCH	Inactivar especialidad	Permite deshabilitar especialidades sin médicos asignados, protegiendo la integridad del historial clínico.
Normativa	/api/v1/config/reglas	PUT	Configurar normativas	Permite ajustar dinámicamente las reglas del desafío de

				escalabilidad.
Auditoría	/api/v1/admin/logs	GET	Consultar logs	Acceso al registro cronológico de acciones para seguridad y control.
Reportería	/api/v1/reportes/solicitados	GET	Reporte de demanda	Obtiene el listado estadístico de los doctores más solicitados.
Privacidad	/api/v1/admin/pacientes/{id}/anonimizar	PUT	Anonimizar datos (GDPR)	Elimina datos identificables a petición del usuario sin destruir el registro clínico.

Doctor (ROLE_DOCTOR)

Profesional de la salud encargado brindar atención medica al paciente.

- **Permisos de escritura:** * Creación de notas de seguimiento post-consulta.
 - Adjuntar documentos.
 - Emitir y firmar digitalmente recetas con hash.
 - Gestión de horarios y tarifas.
 - Configurar perfil.
- **Permisos de lectura:** * Acceder al historial clínico de los pacientes.
 - Acceder a la agenda de citas.
 - Acceder a videollamadas agendadas.

Matriz de permisos: Rol Doctor

Módulo	Endpoint de la API	Método HTTP	Acción de Negocio	Justificación / Regla
Perfil	/api/v1/doctores/perfil	PUT	Configurar perfil	El doctor gestiona de forma autónoma su especialidad, horarios y tarifas.
Agenda	/api/v1/citas/doctor/agenda	GET	Consultar agenda	Permite visualizar cronológicamente las citas reservadas por sus pacientes.
Clínico	/api/v1/historial/{pacienteId}	GET	Ver historial clínico	Acceso a los antecedentes médicos antes o durante la consulta.
Clínico	/api/v1/historial/adjuntos	POST	Adjuntar documentos	Permite subir archivos, exámenes o reportes al expediente del paciente.
Atención	/api/v1/citas/{id}/seguimiento	POST	Registrar nota médica	Redacción de la nota de seguimiento obligatoria post-consulta.
Atención	/api/v1/citas/{id}/videollamada	GET	Enlace de videollamada	Acceso al canal de comunicación

				cifrado para la telemedicina.
Recetas	/api/v1/recetas	POST	Emitir receta digital	Generación de receta firmada con hash, reutilizable hasta 3 veces.

Paciente (ROLE_PACIENTE)

- **Permisos de escritura:** * Adjuntar documentos previos a la cita médica.
 - Reserva citas médicas.
 - Cancelar citas (con reembolso del 80%)
 - Calificación de citas.
- **Permisos de lectura:** * Búsqueda de doctores disponibles por fecha y especialidad.
 - Visualizar su propio historial clínico y recetas asignadas.
 - Acceder a videollamadas agendadas.

Matriz de permisos: Rol Paciente

Módulo	Endpoint de la API	Método HTTP	Acción de Negocio	Justificación / Rule
Búsqueda	/api/v1/doctores/buscar	GET	Buscar disponibilidad	Consulta de doctores filtrando estrictamente por fecha y especialidad.
Reservas	/api/v1/citas/reservar	POST	Reservar cita médica	Creación de la cita sujeta a la confirmación de pago previo (Stripe).
Reservas	/api/v1/citas/{id}/cancelar	POST	Cancelar cita médica	Permite la cancelación; aplica

				reembolso del 80% si es al menos 4h antes.
Atención	/api/v1/citas/{id}/videollamada	GET	Enlace de videollamada	Acceso al canal de comunicación cifrado en el horario de su cita.
Clínico	/api/v1/historial/mi-historial	GET	Consultar historial propio	Acceso exclusivo a sus propios antecedentes bajo normativas HIPAA/GDPR.
Clínico	/api/v1/recetas/mis-recetas	GET	Consultar recetas propias	Visualización de sus recetas digitales vigentes y sus usos disponibles.
Evaluación	/api/v1/citas/{id}/calificar	POST	Calificar la cita	Permite registrar la puntuación de la atención recibida tras la consulta.